

Team Control Number

For office use only

T1 _____

T2 _____

T3 _____

T4 _____

141

Problem Chosen

C

For office use only

F1 _____

F2 _____

F3 _____

F4 _____

2004 Mathematical Contest in Modeling (MCM) Summary Sheet

(Attach a copy of this page to each copy of your solution paper.)

Type a summary of your results on this page. Do not include the name of your school, advisor, or team members on this page.

Summary

Computer systems are protected through multiple layers of defense that consist of policies and technologies. Our task is to determine the appropriate technologies and policies in numbers of security measures.

To achieve the solution, we develop a model that combines Analytic Hierarchy Process (AHP) and nonlinear 0-1 program method. Our model is flexible. The parameters of our model can be adjusted as the situation varies or new measures turn up so that our model can adapt to new situation and adopt new measures easily. In addition, we propose a measure selection method to reduce the mass data that make our method simpler and faster. We use this model to solve the IT security scheme for a new university and give a position paper for model explanation.

We explain our model's extended use, and based on our model, we give a memo for advices on a new technology 'Honeynet', and a memo for the development of IT security in the future.

We analyze the parameter sensitivity and adaptability. The model for IT security scheme is flexible enough to adapt to changing technology and can be applied to different organizations.

IT Security: Keep Hackers and Virus Out!

电子科技大学
邓思滔 李小敏 杨志昂

Introduction

Hackers and virus bring insecure factor in the local area network within an organization. The preventive defensive measures, which consist of security technologies and policies, are important for IT security. The main problem is to determine an optimal mix of security measures that minimizes the latent financial loss along with the investment on procurement, maintenance, and training costs.

We develop a model for the security plan within an organization. The model involves both subjective and objective factors of the organization to strengthen the flexibility. Our model can be applied to the security system on most occasions.

Background

Information technology (IT) plays a vital role in all sectors of society in the 21st century. The main advantage of the Internet is the ability to communicate in a fast, cheap and creative way. Criminal activities in IT environments, such as computer hacker and computer virus, result in various threats and risks. As a consequence, security has become an essential component of IT.

IT security risk consists of three category, confidentiality, integrity and availability. The risks of availability will only be addressed if there is effect on confidentiality or integrity. Threats and risks in the three categories may arise from intentional or unintentional activities and may come from internal or external source. The attacks of hacker or virus often cause damage and chaos, ruin the reputation of companies, and result in loss of financial profits.

Generally speaking, Internet security can be broken down into two separate aspects, client-side security and server-side security. Client-side security usually calls for host-based anti-virus measures and personal firewalls. For a company, security measures for server are more important because many connections converge in a server (web server, LAN server etc.). Server-side security is a large and very complex area, and generally falls within the domain of the system administrator.

Policy and technology compose the preventive defensive measures for IT security. Password, formal security audits, restriction of removable media and user training are common defensive policy, while firewall, anti-virus, intrusion detection, and spam filter are technologies usually used in a company system. Some measures can resist aggression, such as password, firewall; some can give an alarm after attack, such as intrusion detection system; some can help systems recover from damage, such as anti-virus software; and some can analyze the system weakness, such as vulnerability scanning.

Different characters companies ask for various preventive defensive measures. For instance, bank system requires reliable firewall against attacks, while e-mail ISP needs spam filter.

Notations

- P The risk probability, divided into P_C , P_I , P_A , which separately presented the probability of the occurrence of confidentiality, integrity, availability.
- λ_C The priority factor of the confidentiality risk effects on the total opportunity cost C_o
- λ_I The priority factor of the integrity risk effects on the total opportunity cost C_o
- λ_A The priority factor of the availability risk effects on the total opportunity cost C_o
- L_C The level after enhancement of confidentiality
- L_I The level after enhancement of integrity.
- L_A The level after enhancement of availability.

- L_C' The standard level of confidentiality.
- L_I' The standard level of integrity.
- L_A' The standard level of availability.
- $\eta_{C,j}$ The ratio of the contribution to the opportunity cost of confidentiality.
- $\eta_{I,j}$ The ratio of the contribution to the opportunity cost of integrity.
- $\eta_{A,j}$ The ratio of the contribution to the opportunity cost of availability.
- L The level after enhancement, stand for all the L_C, L_I, L_A
- L_0 The initial level (with no security measures), $L_0 = 1$
- Δl The improvement percentage of level
- a The effect parameter, present the relationship between risk's probability and level.
- C_T The total cost (dollar)
- C_O The total opportunity cost (dollar) ,(after using the security measures)
- C_O' The total opportunity cost (dollar) ,(before using the security measures)
- C_S The expense of preventative defensive measures (dollar)
- C_M The total cost for maintenance
- y The time the security system can last (year), after which new security system are needed.
- e The number of apparatuses
- n The number of people who need training
- t The annual training cost per person (dollar/year/person)
- m The annual maintenance cost per person (dollar/year/person)

Model for the Security Measure Choice

Analysis

The likelihood of being a target of hacker or virus depends upon the level of Internet exposure, so dial-up users have less risks than always-on users. Only computer systems with static IP address are concerned in our model, because they are the main costumers of the IT security consulting firm.

If there are no defensive measures, danger is the highest, and the loss because of system vulnerability may be huge. Opportunity cost is the estimation of the latent financial loss according the surveys. We presume that a system without any defensive measures has the lowest level of confidentiality, integrity, and availability, and the probabilities of risks of three categories are 100%. Security policies and technologies may rise the level and bring down the risks, thus they can reduce the potential opportunity costs.

There is no need to install two kinds of anti-virus software on a computer. To avoid waste, only one of the security measures in the same type should be selected out, and not all the appropriate measure types must be included for a device.

We assume the relationship between level and the risk probability can be described as a linear function.

$$P = 1 - a \cdot \frac{L - L_0}{L_0} = 1 - a \cdot \Delta l \quad (1)$$

P is the risk probability, L is the level after enhancement, L_0 is the initial level (with no security measures), Δl is the improvement percentage of level, and a is the effect parameter.

In the linear function, the parameter a represents the variation between the level enhancement and the risks decreasing, and Δl influences the risk probability directly, so the magnitude of levels can be arbitrary. To simplify the calculation, we choose $L_0=1$.

Because those measures bring on expense, on the other hand, they will affect the possible loss, it is a complicated work to balance the potential opportunity costs against the expense of preventive defensive measures. Though security measures are vital, it is unnecessary that a computer system of an organization employs all the available policies and technologies. Threats and risks vary between different organizations. It is important to analyze the risks to make it possible for the arrangement of policies and apparatuses employing with their security intentions. In fact, some technologies such as firewall are needed on most occasions, and some are only for particular use.

The network system of a company is usually made up of some sub-networks for several departments. Different departments have diverse security request. And in the same sub-network, servers and desktops play different roles, as lead to different security requirements and measures. For instance, a bug in the server system may be fatal, while a flaw in desktop terminal may not influence other ones. Host-based security measures fit for the sub-network servers and common desktops, and network –based measures are for the whole network. The elements in a network system vary in security grades and contribution to opportunity costs. A comprehensive IT security plan should include different measures for different security grades in an organization.

The cumulative effects defensive measures incorporation can be calculated with functions

$$L = L_0 \cdot \prod_i (1 + \Delta l_i) \quad (2)$$

Δl_i is the improvement percentage of level due to introduction of Measure i . (table for measure number in Appendix 1.)

Assumptions

- A system with no security measures has a level of 1, and the probabilities of risks in confidentiality, integrity, and availability are 100%.
- Network crime ratio does not change.
- The relationship between level and the risk probability is linear.
- The cumulative effects of defensive measures incorporating can be calculated by cumulative multiplying.

Model Design

We develop an optimization model to determine the security scheme. The objective is to minimize total cost, which is made up of opportunity cost and the expense of securing IT infrastructure. We can write this objective in mathematical form as

$$\text{Min} \quad C_T = C_O + C_S$$

C_T is the total cost (dollar)

C_O is the opportunity cost (dollar) after employ security measures.

C_S is the expense of preventative defensive measures (dollar)

And C_S mainly depend on the security measures adopted, including the procurement or implementation expense, the maintenance expenditure and the sys admin or user training cost. The training and maintenance for one measure lasts until the measure discarded. Since the rapid development of technology area, we can make estimation that the renewing of all the security measures will happen in several years.

$$C_S = C_P + C_M + C_{Tr}$$

$$C_M = y \cdot e \cdot m$$

$$C_{Tr} = y \cdot n \cdot t$$

C_M is the total cost for maintenance, y is the time the security system can last (year), e is the number of apparatuses, n is the number of people need training, m is the annual maintenance cost per person (dollar/year/person) and t is the annual training cost per person (dollar/year/person)

On the basis of Analytic Hierarchy Process (AHP), we can determine the priority factor of the risk effects on the total opportunity cost C_O . The priority suggests the main security factor according to the

security intentions of the organization.

$$\lambda_C = \frac{1}{C_O} \cdot \sum_{i=1}^6 (\eta_{C,j} \cdot C_j) \quad , \quad \lambda_I = \frac{1}{C_O} \cdot \sum_{i=1}^6 (\eta_{I,j} \cdot C_j) \quad ,$$

$$\lambda_A = \frac{1}{C_O} \cdot \sum_{i=1}^6 (\eta_{A,j} \cdot C_j)$$

Opportunity cost due to IT often are the cause of the risks in three categories.

$$C_O = C_O' (P_C \cdot \lambda_C + P_I \cdot \lambda_I + P_A \cdot \lambda_A)$$

Combine (1) and (2),

$$C_O = C_O' \{ [1 - a(L_C - 1)] \cdot \lambda_C + [1 - a(L_I - 1)] \cdot \lambda_I + [1 - a(L_A - 1)] \cdot \lambda_A \}$$

C_O' is the original opportunity costs when no security measures are introduced.

The constrains of different requirement in three security factors are

$$L_C \geq L_C'$$

$$L_I \geq L_I'$$

$$L_A \geq L_A'$$

L_C', L_I', L_A' are the standard levels set according to the requirement of three security factors, and the ratio between the three standard accords with the priority factor of risk effect.

$$L_I' = L_C' \cdot \frac{\lambda_I}{\lambda_C} \quad , \quad L_A' = L_C' \cdot \frac{\lambda_A}{\lambda_C}$$

Besides, given the distinction of the modern network, the standard requirements should be different for various devices. Then amend the security level constraints for all the devices in different security grades. For instance, as to the main server, the standard level L_C' is higher than that of the sub server.

Model Solution

The security system for an organization varies in security intentions, hence, we give advice on the usage of our model on different occasions.

Risk Analysis

Classify the devices (main server, sub-server, PC etc.) within the network into different security grades, the more important the apparatus is, the higher the security grade it is. We suggest 3 grades in a LAN, and more grades can be applied to particular requirements.

The ratio of the risks contribution to each kind of opportunity cost can be obtained in the survey of the latent loss due to IT. If there is no information of the risk estimation, by using AHP, the priority factors of risk effect can be calculated, the relatively effect degree falls into 9 numerical rate [Anderson, 1992]. The direct risk effects on the total opportunity cost can be calculated, and the standard levels L_C', L_I', L_A' can be set down.

Measures Selection

Studies indicate that Internet security firms, famous high-profile companies, and E-commerce websites are the high-risk targets for attack [John Collins, 2003]. The characters of an organization determine the security requests.

According to the security intentions, some measures can be taken into consideration, while the others are not. Choosing appropriate types of technologies and policies can simplify the model calculation. We list the selection principles as below,

1. Measure Purpose

Some measures are for particular use. For instance, network-based vulnerability scanning technology is not suit for the security intentions of campus network, because it cannot reduce the cost, on the contrary, it will increase both opportunity cost and expenses.

2. Measure Cost

If two measures of the same type have the same effect on the user productivity and the three security factors, select the cheaper one.

3. Measure Performance

If two measures of the same type have the same cost, select the one that can have more positive effects on security factors and more negative effects on user productivity.

Security Plan

We use the optimization method to find the chosen ones. The objective is to minimize total cost, and the constraints are the different standard level of security factors for the devices in the network.

If AHP is used, the chosen security policy or apparatus in each type can be selected separately, but the relatively effect degree in the pairwise comparison matrix will bring new error and the combination manner of those chosen ones are complicated because not all of the measures are necessary for security improvement.

We developed a global optimal program to solve the problem. We write a program in LINGO using 0-1-program, the optimal scheme can be computed.

In light of the adjustability of the parameters, the model is applicable on most occasions.

Model Development

The relations and interplay among costs, risk categories, and sources of risk are static relative to the

An IT security consulting firm needs to make their technical database keep pace with the development of technologies. Besides the enhancement of security preventive and defensive measures, new virus and crime means may make progress. Formal security audits may find new weakness and threats of the local area network.

Because new technologies occur all the time, the data supplement is important. As the range of security measures expands, the calculation may be more complex. However, the selection principles assure that unsuitable measures will not be contained in the 0-1-program process.

We use our model to get the appropriate measures for the new university campus network given, with assumptions below:

We divide the devices in the network into three security grades as shown in figure 1. The main server, which is the ‘door’ of the whole campus network, is the first security grade and require highest standard of confidentiality, integrity and availability. Network-based measures are for the main server. Sub-severs are settled in the 10 academic departments, dormitory sub-network, and the web sites for the intercollegiate athletics department, the admissions office, the registrar’s office, the bookstore, the student health center. We put those sub-servers in the second security grade, and they require host-based measures. The staff and faculty computers are in the third grade. We presume that the desktops in third grade need only firewalls, host-based anti-virus, password policy, removable media policy, and training policy. For the student users, only one system administrator is appointed to operate the server for the dormitory sub-network.

[illegible]
$$\lambda_C = 0.482, \quad \lambda_I = 0.401, \quad \lambda_A = 0.117$$

<http://202.115.21.138/wlxt/ncourse/model/web/math/front/StudyArea/mht...> 2007-10-25

other two standard levels can be computed as

$$L_I' = L_C' \cdot \frac{\lambda_I}{\lambda_C}, \quad L_A' = L_C' \cdot \frac{\lambda_A}{\lambda_C}$$

Measures Selection

According to the rule of measures selection introduced before, 36 appropriate security apparatuses are chosen from 74 ones, thus, the range of available schemes is narrower. (results are in Appendix 2)

Assumption

- The campus IT security system lasts for 5 years;
- The current opportunity cost is only for one year;
- The priority factors of the devices in three security grade are 0.4, 0.4, 0.2 .

Security Plan

We choose the effect parameter $\alpha = 0.3$. (The program written in LINGO is in Appendix 3, 4, 5 .) the results are in Table 1.

For the whole campus network, formal security audits policy should be implemented in order to find out the disadvantages of the security measures. Formal security helps a lot to renew the security measures.

The average annual total cost is \$4,948,237.

The total cost in the first year is \$6,271,589.

The maintenance and training cost is \$4,617,399 in all.

Table1

The chosen technologies and policies for a new university

Measures & policies	Desktop	Sub-server	Server
Host-based Firewall	Lava	Lava	
Network-based Firewall			Network defense
Host-based anti-virus	Bug Killer	Bug Killer	
Network-based anti-virus			System Splatter
Network-based IDS			Network Eye
Network-based SPAM Filter			Spam Stoper
Data Redundancy			Bytes
Service Redundancy			Robust Solutions
Strong Password Policy	Strong Password	Strong Password	
No Password Policy			
Formal Security Audits	Formal Security Audits	Formal Security Audits	Formal Security Audits
Disallow Wireless	-	Disallow Wireless	-
Allow Wireless	-		-
Restrict Removable Media	Restrict Removable Media		
Unmonitored Personal Use	-		-
Restricted Personal Use	-	Restricted Personal Use	-
User Training Required	User Training		

	Required		
Sys Admin Training Required		Sys Admin Training Required	

Table 2.
Sensitive Analysis

a	Main server		Sub-server		Host	
	Cost \$/year	Opportunity cost(\$/year)	Cost \$/year	Opportunity cost(\$/year)	Cost \$/year	Opportunity cost(\$/year)
0.1	3150710	3059174	3485228	3239236	1556422	1490022
0.2	2615562	2501026	2929788	1499393	1249386	1146586
0.3	2080074	1965540	1893485	463089	929678	826878
a	Main server		Sub-server		Host	
	Cost %Diff	Opportunity cost(%Diff)	Cost %Diff	Opportunity cost(%Diff)	Cost %Diff	Opportunity cost(%Diff)
0.1	51.47%	55.64%	84.06%	599.48%	67.42%	80.20%
0.2	25.74%	27.24%	54.73%	223.78%	35.43%	38.66%
0.3	1	1	1	1	1	1

Parameter a is the effect parameter.

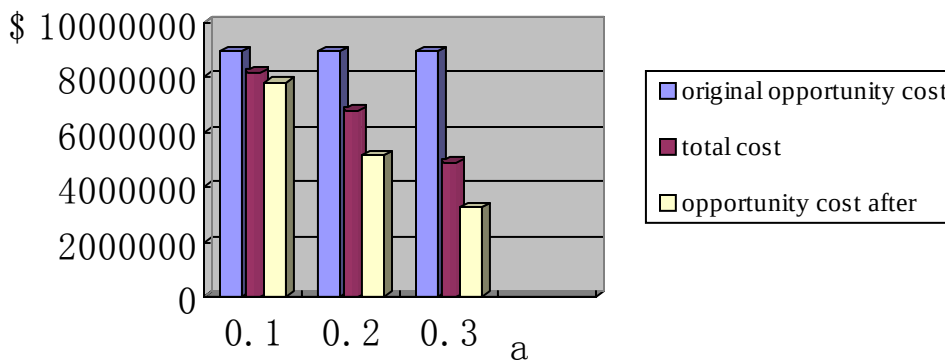


Figure 2 Sensitive Analyses

Sensitivity Analysis

For a model incorporating as many parameters as this one does, it is vital to determine which introduces the greatest error. Given a $\pm 10\%$ deviation in the value of the parameter, we calculate the change in the value that the complete model leads to and find that a is the parameter that has the greatest effect. Table 2 and Figure 2 summarize the parameter that has significant effects; the model is fairly insensitive to the value of other parameters.

Position Paper to the University President

The Internet brings not only the abundant information to teachers and students, but also the IT security problem. Once the campus computer system connects to the Internet, your university must face the modern high-tech network crimes.

It is known to all that security measures have to be taken to prevent and defense the attacks of hacker or virus. But a campus network system is much more complicated than a personal computer. How much should spend on IT security measures to prevent potential loss? It seems easier to explain the main purpose like the following:

1. The opportunity costs are low.
2. The procurement, maintenance, and system administrator training costs are low.

The problem is to find an optimal mix of preventive defensive measures that minimize the potential opportunity costs along with the investment on security measures.

Our IT security system model can be applied to determine the security measures on most occasions, and we can give solution of your campus network security.

Structure of Campus Network

Given the reality that your university have 10 academic departments and 5 websites of diverse services, we presume that campus network structure includes the main server, sub-severs for various departments, and the interface for student dormitory network. Those devices can be divided into three security grades (as in Figure 3).

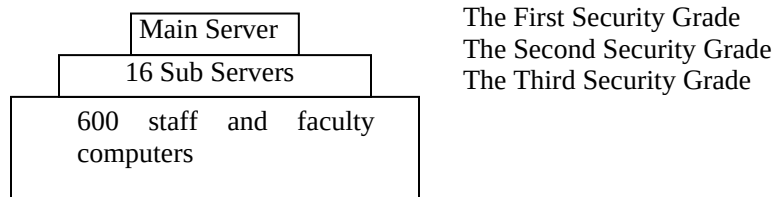


Figure 3. Three security grades in the campus network

In our suggestion scheme, the requirements of each security grade are in Table 3.

Table 3.
The Requirements of 3 Security Grades

	Grade 1	Grade 2	Grade 3
Device	1 Main server	16 Sub-server	600 desktops
Sys Admin	3	16	2
Measures	Network -based	Host-based	Host-based
Priority Factor of the Total Opportunity Cost	0.4	0.4	0.2

If the campus expands or departments increasing, the classification of security grades and the requirements may need to modify. Our model has the advantages that it brings in the artificial decisions according to the actual situation.

Risk analysis

As to the campus network, the troubles caused by hackers or virus include:

- Illegal access to confidential academic record and exam data
- System disorder because of malicious activities
- Important data altered or deleted by illegal intruders

- Service failures because abnormal traffic jam produced by bulk requests.
- Propagation of virus

Therefore, security measures should pay attention to the confidentiality of the proprietary data (such as the research data and exam data), the integrity of the system data and other important contents, and the availability for authorized users.

In our model, we analyze the current opportunity costs and risk category contribution to find that risks of confidentiality and integrity may be the main cause of opportunity costs. Figure 4 shows the risks priority effect on the total potential opportunity costs.

The priority factors of effect on the total potential describe the main factor resulting in the most loss in mathematics language. It helps a lot to introduce the actual security intentions to the mathematics model.

If the effects of the risk on each kinds opportunity cost are given, the analysis of the main factor resulting in the latent loss can be accurate. Even without the original data, the main factor can be determined by using pairwise comparison from experiences. But if the details of the security intention are unknown, the pairwise comparison made by subjective judge may cause error.

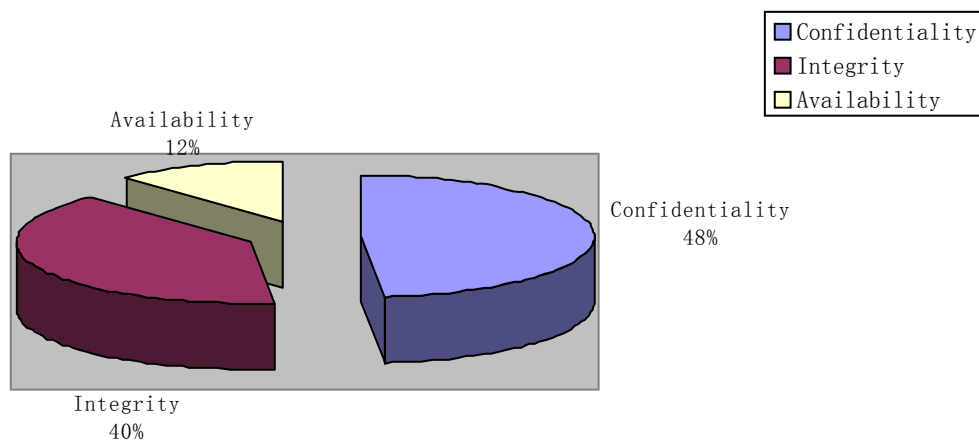


Figure 4. The risks priority effect on the total opportunity costs

Security Measure Selection

The selection principles combine the security purpose, cost, and performance. However, the actual time the security measures may be different, the discarding of some measures because of higher total maintenance cost within several years may not be appropriate. Therefore, a more reasonable selection require more information about the performance of the security measures.

Security Measure Plan

Without the data of the estimation of the original revenue, our model cannot predict the accurate financial loss caused by decreasing of user productivity. But our security measure selection principles take the guarantee of the stability of user productivity into account, as to improve the model feasibility.

According to the solutions, the levels of confidentiality, integrity and availability are improved evidently, as shown in Figure 5.

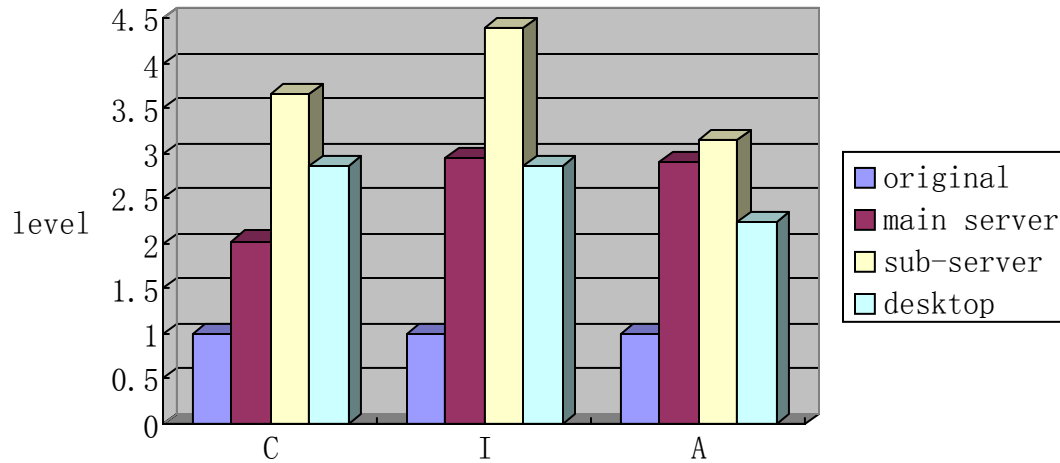


Figure 5. The improvement of the security level

Updating and Upgrading

If the technical data sheets are updated in accord with the development of the security technologies, the model can work well to satisfy the requests of most organizations.

However, our method is choosing optimal mix of preventive defensive measures within the range of known technologies and policies. The model itself is not able to predict the change of security measures. If a significant revolution takes place in the technology field, our model may fail to deal with the real problems.

Security Plan for High Risk Websites

Opportunity costs due to IT security which an organization may face include litigation, loss of proprietary data, consumer confidence, direct revenue loss, reconstruction of data and reconstruction of service. To different organizations, the contributions of risks of each kind of opportunity costs are almost the same, but the possibilities of each kind of opportunity costs varies greatly, because of the different services they provide. We discuss two kinds of websites: the commercial company and the websites provide a search engine. They will face different types of opportunity cost, but they have a same character: they are all facing high risk of being attacked.

Analysis of the opportunity costs:

The commercial companies and famous search engines are the targets of the hackers. For hacker, to achieve the success of broke into a famous website is much more flourish than intrude into an unknown website. They can get more financial profit too. So the commercial companies and websites provides search engines will face much higher risks of being attacked than other websites.

If being attacked, the commercial companies will face a serious problem: loss of proprietary data and consumer confidence. The proprietary data of a commercial company contains commercial secrets, the loss of the data does not only means disastrous loss, but also mass litigation from consumers, so proprietary data loss, litigation, consumer confidence take an important part in the opportunity costs of a commercial company.

The websites provide search engines may face costs associated with data reconstruction and service reconstruction and possible loss of consumer confidence.

Our model is able to work for this type of organizations. Only the initial data of the opportunity costs has to be changed, the model itself does not need to be changed. If the organizations want to limit the

expense on measures, we only need to add some constraints to the optimization method. Our model can be easily adapted to this type of organizations.

Memo for Honeynets

What is honeynet?

A honeynet is a network of computers with production systems that is designed to be compromised. It can watch incoming and outgoing connections, monitoring all activities happens within the honeynet.

The common components of a honeynet are:

A firewall computer, which logs all incoming/outgoing connections and provides NAT service and some Denial of Service protection;

An intrusion detection (IDS) computer can supervise all of the network traffic. It also logs all the network traffic and looks for known exploits and attacks;

A remote syslog computer. All commands an intruder would use are sent to syslog. Syslog is then set to remote log to the remote syslog box;

The honeypot itself, which can detect encrypted attacks in networks and capture the latest on-line credit card fraud [Michael Clark, 2001].

What can a honeynet do?

In general, honeynets can be used for both production purposes and research purpose. For production purpose, honeynets are used to protect an organization including preventing, detecting, or helping organizations respond to an attack. For research purposes, honeynets are used to collect information, which is useful in studying the trends in attacker activity, in early warning and prediction, and in gathering law enforcement.

Classification and costs of honeynets

There are two kinds of honeynets: the traditional honeynet and visual honeynet. Traditional honeynet is a real net of computers while visual honeynet is just a simulated system, which can be realized by software.

The cost of traditional honeynet is very high while the cost of visual honeynet is relatively lower.

Advantages of a honeynet

- Honeynet is against both virus and human attackers.
- Honeynet makes an excellent incident response tool. It responses more quickly than firewalls, IDSs and Vulnerability Scannings, when scanning an intruder or virus. Thus it brings in more users' confidence.
- A honeynet existing in the real network will attract almost all the intruders, protecting the real system from being attacked. Besides, the information gathered from honeynet can help establish a more effective security strategy.
- When a honeynet is attacked, the administrator has to capture all the behaviors of the intruder and take reactions immediately. So honeynet is a good tool to gain experience in responding to incident attack.
- Many people take it a challenge to have their networks attacked. A honeynet can be used to identify a failure or breakdown in prevention, examining the security of the network if a mirror of the production system is made to be the honeypot.
- The honeynet helps to collect extensive information on a variety of threats. It's a useful tool to study the targets, methods and tools used by intruders.

Disadvantages of a honeynet

- Its cost is relatively high comparing with other tools, especially for the traditional honeynet. Many

programs of honeynets failed in the end for the lack of fund.

- The honeynet's authority of administrator may be taken over by intruders, which may result in the risk of being used by bad guys to harm other systems.
- Honeynets can only track and capture activity that directly interacts with them. It is just a waste of money when having no intruders probe into.

Legality of honeynet

Debates exist on the legality of honeynet such as: entrapment, privacy and liability. There are many different opinions about it. But those are personal ideas, for no case of honeynet has happened so far and no exceptive laws on honeynets has been established. With laws nowadays, honeynet seems a legal one.

Tendency of honeynet

Honeynet is a new kind of tool with enormous values. With the development of technology, especially with the development of visual honeynet, the cost of honeynet will be greatly reduced. More and more honeynets will be used in the near future not only for research but also for anti-intruders.

Suggestions to different organizations

Whether to install a honeynet, relies on purposes of the organization.

To organizations mainly researching the network security, honeynet is a good choice to study the skills using by intruders.

To networks with higher risk of being attacked, such as search engines and networks with commercial secrets, financial secrets and academic secrets, a honeynet is recommended badly. Honeynet is used to confuse the attacker, to make him waste his time and resources interacting with honeynets. Meanwhile, the organization has detected the attacker's activity and has the time to respond, to stop or to mitigate the damage they do.

To common networks with little risk such as webs for schools, honeynet will never be considered. Because the cost is too high other measures can be recommended.

Conclusions

Honeynet is a very valuable tool for research, intelligence and education. Information gathered from honeynets can be analyzed to monitor attack trends, to educate people and to gain law enforcement. Consider the funds, purpose and the risk of being attacked when you give consults on whether to use a honeynet.

Analysis of the Development of the Direction of IT in the Future

In the future, the bandwidth of the net is to be broadened. Wider band means more ways of sending messages, which will result in difficulties for firewalls and other security methods, which depend on watching incoming and outgoing data.

Another tendency for the computers is to become wireless. In fact, wireless technology is becoming more popular with the computer users, thanks to its convenience. Because of the popularization of wireless technology, the problem of wireless security reveals. A significant factor about wireless connection is that it will increase users who are difficult to track. Thus, a hacker will have less opportunity to be tracked if he connects wirelessly than wired. New technologies are in need for improvement of wireless security.

Based on our analysis, we give the memo for the future of IT security below.

Memo for Future Outlook

Analysis

Technologies and technical specifications will change rapidly over time, the development of technologies and technical specifications have a deep influence on IT security. In general, the tendency of the computers' development is to become faster and more convenient, of which wider bandwidth and wireless plays an important roll. Of course the security is also closely related to them. Our model can be used to give a quick response to the uncertainty of future. We analyze the future direction of information technology and based on the analysis, we make some recommendations for the future development of the IT security below:

1. Wireless will soon be an important method of connection, thanks to the convenience it brought. Wireless will bring more users to the web, but also more risks. Hackers who connect the server wirelessly are more difficult than wired to track and resist. For instance, he can log in your system at anytime anywhere he wants, or it is hard to locate a hacker who broke into a bank system if he is on some transportations. Hence, particular methods and technologies are needed for wireless equipments and systems.
2. The width of net bandwidth will be broadening in the future. Broader and wider bandwidths require more effective and safer servers. The speed of server will be important for the users, so the effective of security methods need to be enhanced to provide better service.
3. The technologies have the tendency for combine together. A firewall will not only be a single firewall which block suspicious data but also can do some anti-virus or vulnerable scanning work. In the same time, the anti-virus software or vulnerable scanning system may also block suspicious data flow from network.
4. There are many technical protocols for data transportation. A server must adopt most of them to meet the requirements of different users, so the security methods must be adapted to all the protocols. Considering that technical specifications will change rapidly and more protocols will be proposed, the security measures in the future should have a good adaptability and compatibility. And to decide which one to use will also be more complex than before.
5. The security system should not be conservative that only take passive methods for defending hackers, it should use more positive methods, such as use honeynet to collect information of hackers' various methods and prevent it.

The development of technologies brought convenience to both hacker and hacker-defender. We can use technologies to improve the IT security. Thanks to the fast changing of technical specifications and development of the technologies, the future is changeful and hard to foretell. Our model cannot be used to foretell the future. However, our model can be used to give a quick response to it.

The future's uncertainty leads to the variety of security methods. Our model is suitable for responding quickly to the uncertainty because its good adaptability and compatibility. If a new measure is introduced, its influence on the risk categories (confidentiality, integrity, and availability) is introduced too. Given them as parameters, we add the new measure into the optimal method then whether it is suitable can be determined. It is simple to do it with our model.

The future's uncertainty also leads to changes of risk levels and ratios between different types of opportunity costs. In order to adapt to that situation, we only need to change a few parameters in our model. The course is simple and can be done quickly. Our model is compatible with changing risk levels and opportunity cost and can response quickly.

In our model, the parameter a is used to estimate the influence of the risks' level change on the opportunity costs, for different organizations and companies a can be modified to different values. So does the initial contribution of risk categories to the opportunity cost. By changing a we can adapt the model to various situations that are due to the uncertainty of future.

In a word, though the future is changeful, we can be quick-responded to the changes by using our model, and can be active in anticipating the future direction and giving advices to companies in information technology field at the first time.

Strength

- Our model can incorporate various situations: colleges, search engines, web companies, etc. it can be easily adapted to different organizations.
- Our method is robust, so new technologies and software can be introduced into this model and immediately used for estimation and calculation. Only a few parameters need to be changed in order to adopt new technologies and software.
- The costs we estimated are much lower than the original costs, which is the main point. The arrangements we made are applicable for a college.
- The model can be used for variable purpose, not only for policies and technologies determining, but also for new technology evaluating.
- When calculated on computer our model can give the results quickly.

Weakness

- This model depends on computer for calculation and if without computer, the solution of it cannot be easily obtained.
- Some of the assumptions and parameters of this model are not easy to determine, the inaccuracy of parameter estimation will lead to the inaccuracy of results.

Conclusion

The key to obtain an optimal security scheme is to choose efficient, less expensive security measures. Security grade classification, risk assessment, and initial measure selections are used to introduce the subjective factors of a LAN into our model.

The optimal solution mainly depends upon the value of effect parameter α and standard levels of confidentiality, integrity and availability (L_C', L_I', L_A'). The model offers some adjustable parameters to adapt to different organizations. The solution for campus network is promising; the security measures reduce the opportunity costs largely. New technologies may affect the complexity of calculation, but not the basic method of our model.

References

Anderson Sweeney Williams. 1992. Quantitative Methods for Business (Fifth Edition)

John Collins. 2003. Illegal Internet Feature.
Available at <http://www.design-ireland.net/>

Fortinet. 2003. Solutions: Fortinet in Education.
Available at <http://www.fortinet.com.cn/solutions/>

February 2004. IT security and crime prevention methods. Available at
<http://www.interpol.int/Public/TechnologyCrime/CrimePrev/ITSecurity.asp#2>

Infrastructure: Wireless; LANS, WDCN, Security
 Available at http://www.michigan.gov/documents/Policy_1420_59123_7.pdf

Lance Spitzner Honeypots: Are They Illegal? 2003
<http://www.securityfocus.com/infocus/1703>

Michael Clark Virtual Honeynets 2001
<http://www.securityfocus.com/infocus/1506>

Honeynet Project Know Your Enemy: Honeynets 2003
<http://www.honeynet.org>

Appendix 1: Table for Measure Number

Number	Name	Number	Name	Number	Name
1	ntelli-Scan	29	Enterprise Inoculation	57	Scanner
2	Shield	30	Global Protect	58	Health Check
3	Lava	31	Bug Zapper	59	Net Assesment
4	ProtectIT	32	Enterprise Stomper	60	SCT scanner
5	Blockade	33	Enterprise Fogger	61	NetStat
6	Blocker	34	System fixer	62	VulneScan
7	Watertight	35	System Doctor	63	Sonic Data
8	Barrior	36	Blue Sky	64	Data Soutions
9	EnterpriseSolution	37	Acer Security	65	Data R Us
10	Network defense	38	Protection	66	Bytes
11	System Inoc	39	Data Watcher	67	Digital Solutions
12	Protection	40	Data Inc	68	Data
13	Acera	41	Correction Inc	69	Web King
14	Plunger	42	Detect IT	70	Redundant
15	Firebase	43	Security Associates	71	Servies
16	Enerprise Lava	44	Network Traffic ID	72	ServU
17	Draco	45	Unitec	73	Robust Solutions
18	Bug Killer	46	Network Eye	74	Duplicity
19	Anti-V	47	Watcher	75	Dito
20	Insecticide	48	Spam Stoper	76	Strong Passwords
21	Smasher	49	Mail Control	77	No Password
22	Stomper	50	Postman	78	Policy
23	The Swatter	51	Mail Scrubber	79	Formal Security
24	Mckiller	52	Spam Meiseter	80	Audits
25	Fogger	53	Email Valve	81	Disallow Wireless
26	Innoculator	54	Email Valve	82	Allow Wireless
					Restrict
					Removable Media
					Unmonitored
					Personal Use
					Restricted
					Personal

27	Enterprise Stopper	55	Acer Inc	83	Use/Detailed User Tracking
28	System Splatter	56	Hole Plugger	84	User Training Required
					Sys Admin Training Required

Appendix 2: Initial Measure Selection results

(Table1 and Table 2)

Table1
Host-based

Number	Name	Number	Name	Number	Name
1	ntelli-Scan	8	Barrior	23	The Swatter
2	Shield	18	Bug Killer	25	Fogger
3	Lava	19	Anti-V	26	Innoculator
6	Blocker	20	Insecticide		
7	Watertight	22	Stomper		

Table 2
Network-based

Number	Name	Number	Name	Number	Name
10	Network defense	36	Blue Sky	48	Spam Stoper
11	System Inoc	37	Acer Security	49	Mail Control
12	Protection	38	Protection	50	Postman
16	Enerprise Lava	39	Data Watcher	51	Mail Scrubber
17	Draco	40	Data Inc	54	Email Filter
28	System Splatter	41	Correction Inc	66	Bytes
31	Bug Zapper	43	Security Associates	67	Digital Solutions
32	Enterprise Stomper	45	Unitec	68	Data
34	System fixer	46	Network Eye	72	Robust Solutions
35	System Doctor	47	Watcher	74	Dito

Appendix 3: Model for host's technologies and policies choice

These programs are written in LINGO,

```

model:
!model for host's technology arrangements;
@bin(x1);@bin(x2);@bin(x3);@bin(x4);@bin(x5);
@bin(x6);@bin(x7);@bin(x8);@bin(x9);@bin(x10);@bin(x11);@bin
(x12);@bin(x13);
@bin(x14);
@bin(x15);
@bin(x16);
@bin(x17);

```

```

lc=(1+x1*0.28+x2*0.2+x3*0.28+x4*0.1+x5*0.2+x6*0.21)*
(1+x7*0.28+x8*0.29+x9*0.2+
x10*0.1+x11*0.19+x12*0.19+x13*0.16)*(1+x14*0.28+x15*(-0.5))*
(1+x16*0.05)*(1+x17
*0.3);

li=(1+x1*0.28+x2*0.15+x3*0.28+x4*0.1+x5*0.2+x6*0.19)*
(1+x7*0.28+x8*0.25+x9*0.2+
x10*0.1+x11*0.18+x12*0.16+x13*0.1)*(1+x14*0.28+x15*(-0.5))*
(1+x16*0.05)*(1+x17*
0.3);

la=(1+x1*0.18+x2*0.1+x3*0.18+x4*0.05+x5*0.2+x6*0.2)*
(1+x7*0.18+x8*0.18+x9*0.2+
x10*0.05+x11*0.05+x12*0.06+x13*0.06)*(1+x14*0.18+x15*(-0.5))*
(1+x16*0.05)*(1+
x17*0.3);

bili=1.3;
a=0.3;
!costs calculation;
!training/year/sysadm;
chengben1=((x1+x2+x3+x4+x5+x6+x7+x8+x9+x10+x11+x12+x13)
*1000+x14*12000+x15*0+
x16*12000+x17*0)*2;
!procurement/implementation;
chengben2=
((x1*45+x2*50+x3*35+x4*15+x5*10+x6*10+x7*20+x8*12+x9*8+x10*5+x11*8+
x12*3+x13*5)*600+x14*45000+x15*0+x16*20000+x17*45000);
!training/year/user;
chengben3=(x14*5+x15*0+x16*10+x17*10)*600;
!maintenance;
chengben4=x14*12000+x15*0+x16*12000+x17*12000;

opcost=((1-(lc-1)*a)*(0.55*3800000+0.7*1500000+0.4*2900000)*0.2+(1-
(li-1)*a)
*(0.45*3800000+0.3*1500000+0.3*2900000+400000+80000+0.3*250000)*0.2+
(1-(la-1)
*a)*(0.3*2900000+0.7*250000)*0.2);

min=chengben1+chengben2+chengben3+chengben4+opcost;

(1+x1*0.28+x2*0.2+x3*0.28+x4*0.1+x5*0.2+x6*0.21)*
(1+x7*0.28+x8*0.29+x9*0.2+x10*0.1+x11*0.19+x12*0.19
+x13*0.16)*(1+x14*0.28+x15*(-0.5))*(1+x16*0.05)*(1+x17*0.3)>=bili;

(1+x1*0.28+x2*0.15+x3*0.28+x4*0.1+x5*0.2+x6*0.19)*
(1+x7*0.28+x8*0.25+x9*0.2+x10
*0.1+x11*0.18+x12*0.16+x13*0.1)*(1+x14*0.28+x15*(-0.5))*(1+x16*0.05)*

```

```

(1+x17*0.3)
>=bili*343/4.12;

(1+x1*0.18+x2*0.1+x3*0.18+x4*0.05+x5*0.2+x6*0.2)*
(1+x7*0.18+x8*0.18+x9*0.2+x10*
0.05+x11*0.05+x12*0.06+x13*0.06)*(1+x14*0.18+x15*(-0.5))*(1+x16*0.05)
*(1+x17*0.3)
>=bili*1/4.12;

x1+x2+x3+x4+x5+x6<=1;
x7+x8+x9+x10+x11+x12+x13<=1;
x14=1;x16=1;x17=1;

```

Appendix 4: Model for sub-servers' technologies and policies choice

model:

```

!2nd-server;

@bin(x1);@bin(x2);@bin(x3);@bin(x4);@bin(x5);
@bin(x6);@bin(x7);@bin(x8);@bin(x9);@bin(x10);@bin(x11);@bin
(x12);@bin(x13);
@bin(x14);@bin(x15);@bin(x16);@bin(x17);@bin(x18);@bin(x19);@bin
(x20);
@bin(x21);@bin(x22);@bin(x23);@bin(x24);@bin(x25);
lc=(1+x1*0.28+x2*0.2+x3*0.28+x4*0.1+x5*0.2+x6*0.21)*
(1+x7*0.28+x8*0.29+x9*0.2+
x10*0.1+x11*0.19+x12*0.19+x13*0.16)*(1+x14*0.28+x15*(-0.5))*
(1+x16*0.05+x17*
(-0.3))*(1+x18*(-0.1)+x19*0.28)*(1+x20*0.3);

li=(1+x1*0.28+x2*0.15+x3*0.28+x4*0.1+x5*0.2+x6*0.19)*
(1+x7*0.28+x8*0.25+x9*0.2
+x10*0.1+x11*0.18+x12*0.16+x13*0.1)*(1+x14*0.28+x15*(-0.5))*
(1+x16*0.05+x17*(-
0.3))*(1+x18*(-0.1)+x19*0.28)*(1+x20*0.3)*
(1+x21*0.2+x22*0.1+x23*0.15)*(1+x24*
0.2+x25*0.15);

la=(1+x1*0.18+x2*0.1+x3*0.18+x4*0.05+x5*0.2+x6*0.2)*
(1+x7*0.18+x8*0.18+x9*0.2+
x10*0.05+x11*0.05+x12*0.06+x13*0.06)*(1+x14*0.18+x15*(-0.5))*
(1+x16*0.05+x17*
(-0.3))*(1+x18*(-0.1)+x19*0.18)*(1+x20*0.3)*
(1+x21*0.2+x22*0.1+x23*0.15)*(1+

```

```

x24*0.2+x25*0.15);

bili=1.6;
a=0.3;
!cheng ben ji suan;

!training/year/sysadm;
chengben1=
((x1+x2+x3+x4+x5+x6+x7+x8+x9+x10+x11+x12+x13+x21+x22+x23+x24+x25)*
1000+x14*12000+x15*0+x16*0+x17*30000+x18*0+x19*30000+x20*30000)*16;
!procurement/implementation;
chengben2=
((x1*45+x2*50+x3*35+x4*15+x5*10+x6*10+x7*20+x8*12+x9*8+x10*5+x11*
8+x12*3+x13*5)
*16+x14*45000+x15*0+x16*20000+x17*45000+x18*20000+x19*45000+
x20*45000+(x21*250000+x22*150000+x23*100000+x24*10000+x25*10000)*16);
!training/year/user;
chengben3=(x14*5+x15*0+x16*10+x17*10+x18*0+x19*5+x20*0);
!maintenance;
chengben4=x14*12000+x15*0+x16*12000+x17*12000+x18*0+x19*12000;
!maintenance/year/computer;
chengben5=(x21*3000+x22*3000+x23*10000+x24*10000+x25*10000)*16;

opcost=((1-(lc-1)*a)*(0.55*3800000+0.7*1500000+0.4*2900000)*0.4+(1-(li-1)*a)*
(0.45*3800000+0.3*1500000+
0.3*2900000+400000+80000+0.3*250000)*0.4+(1-(la-1)*a)*(0.3*2900000+0.7*250000)*0.4);

min=chengben1+chengben2+chengben3+chengben4+chengben5+opcost;

(1+x1*0.28+x2*0.2+x3*0.28+x4*0.1+x5*0.2+x6*0.21)*
(1+x7*0.28+x8*0.29+x9*0.2+
x10*0.1+x11*0.19+x12*0.19+x13*0.16)*(1+x14*0.28+x15*(-0.5))*
(1+x16*0.05+x17
*(-0.3))*(1+x18*(-0.1)+x19*0.28)*(1+x20*0.3)>=bili;

(1+x1*0.28+x2*0.15+x3*0.28+x4*0.1+x5*0.2+x6*0.19)*
(1+x7*0.28+x8*0.25+x9*0.2
+x10*0.1+x11*0.18+x12*0.16+x13*0.1)*(1+x14*0.28+x15*(-0.5))*
(1+x16*0.05+x17*
(-0.3))*(1+x18*(-0.1)+x19*0.28)*(1+x20*0.3)*
(1+x21*0.2+x22*0.1+x23*0.15)*(1+
x24*0.2+x25*0.15)>=bili*3.43/4.12;

(1+x1*0.18+x2*0.1+x3*0.18+x4*0.05+x5*0.2+x6*0.2)*
(1+x7*0.18+x8*0.18+x9*0.2+
x10*0.05+x11*0.05+x12*0.06+x13*0.06)*(1+x14*0.18+x15*(-0.5))*
(1+x16*0.05+x17
*(-0.3))*(1+x18*(-0.1)+x19*0.18)*(1+x20*0.3)*

```

```
(1+x21*0.2+x22*0.1+x23*0.15)*(
1+x24*0.2+x25*0.15)>=bili*1/4.12;
```

```
x1+x2+x3+x4+x5+x6<=1;
x7+x8+x9+x10+x11+x12+x13<=1;
x14+x15<=1;
x16+x17<=1;
x18+x19=1;
x21+x22+x23<=1;
x24+x25<=1;
x3=1;x7=1;x14=1;x16=1;x18=1;
```

Appendix 5: Model for main-server's technologies and policies choice

```
model:
!main server;
@bin(x1);@bin(x2);@bin(x3);@bin(x4);@bin(x5);
@bin(x6);@bin(x7);@bin(x8);@bin(x9);@bin(x10);@bin(x11);@bin
(x12);@bin(x13);
@bin(x14);@bin(x15);@bin(x16);@bin(x17);@bin(x18);@bin(x19);@bin
(x20);
@bin(x21);@bin(x22);@bin(x23);@bin(x24);@bin(x25);
@bin(x26);@bin(x27);@bin(x28);
@bin(x29);@bin(x30);

!c level increasing;
lc=(1+x1*0.3+x2*0.2+x3*0.25+x4*0.1+x5*0.18)*
(1+x6*0.3+x7*0.25+x8*0.25+x9*0.1
+x10*0.1+x11*0.1+x12*0.1+x13*0.1)*
(1+x14*0.2+x15*0.2+x16*0.09+x17*0.15+x18*
0.18+x19*0.2+x20*0.2);
!i level increasing;

li=(1+x1*0.3+x2*0.15+x3*0.25+x4*0.1+x5*0.17)*
(1+x6*0.3+x7*0.25+x8*0.2+x9*0.09
+x10*0.07+x11*0.02+x12*0.1+x13*0.1)*
(1+x14*0.2+x15*0.2+x16*0.11+x17*0.15+x18*
0.17+x19*0.21+x20*0.19)*(1+x26*0.2+x27*0.1+x28*0.15)*
(1+x29*0.2+x30*0.15);
!a level increasing;
la=(1+x1*0.2+x2*0.2+x3*0.13+x4*0.05+x5*0.1)*
(1+x6*0.2+x7*0.13+x8*0.13+x9*0.03
+x10*0.05+x11*0.12+x12*0.05+x13*0.05)*
(1+x14*0.2+x15*0.2+x16*0.13+x17*0.15+x
```

```

18*0.17+x19*0.22+x20*0.21)*
(1+x21*0.15+x22*0.02+x23*0.01+x24*0.01+x25*0.03)*
(1+x26*0.2+x27*0.1+x28*0.15)*(1+x29*0.2+x30*0.15);

```

```
temp=2.0;
```

```
f=0.4;
```

```
!maintenance/year/computer;
```

```
chengben1=(x1*1500+x2*1000+x3*1500+x4*0+x5*500+x6*0+x7*0+x8*0+x9*0
+x10*0+x11*0+x12*0+x13*0+x14*50+x15*100+x16*0+x17*0+x18*20+x19*35+
x20*0+x21*0+x22*0+x23*0+x24*0+x25*0+x26*3000+x27*3000+x28*10000+x29
*10000+x30*10000)*1;
```

```
!procurement;
```

```
chengben2=(x1*17500+x2*10000+x3*10000+x4*2000+x5*3000+x6*1000+x7*600
+x8*300+x9*250+x10*300+x11*400+x12*300+x13*250+x14*19000+x15*20000+x16
*15000+x17*9000+x18*5000+x19*4000+x20*3000+x21*45000+x22*30000+x23*300
+x24*5000+x25*5000+x26*250000+x27*150000+x28*100000+x29*10000+x30*1000

```

```
!training/year/admin;
```

```
chengben3=(x1*4000+x2*4000+x3*2000+x4*3500+x5*2500+x6*2500+x7*1000+x8
*1000+x9*750+x10*1500+x11*2000+x12*1000+x13*1000+x14*5000+x15*7000+x16
*6000+x17*5000+x18*7000+x19*2000+x20*1000+x21*1000+x22*1500+x23*2000+
x24*1000+x25*1000+x26*1000+x27*1000+x28*1000+x29*1000+x30*1000)*3;
```

```
opcost=((1-(lc-1)*0.3)*(0.55*3800000+0.7*1500000+0.4*2900000)*0.4+(1-
(li-1)*0.3)*(0.45*3800000+0.3*1500000+0.3*2900000+400000+80000+0.3*
250000)*0.4+(1-(la-1)*0.3)*(0.3*2900000+0.7*250000)*0.4);
```

```
min=opcost+chengben1+chengben2+chengben3;
```

```

(1+x1*0.3+x2*0.2+x3*0.25+x4*0.1+x5*0.18)*(1+x6*0.3+x7*0.25+x8*0.25+x9
*0.1+x10*0.1+x11*0.1+x12*0.1+x13*0.1)*
(1+x14*0.2+x15*0.2+x16*0.09+x17*
0.15+x18*0.18+x19*0.2+x20*0.2)>=
temp;

```

```

(1+x1*0.3+x2*0.15+x3*0.25+x4*0.1+x5*0.17)*(1+x6*0.3+x7*0.25+x8*0.2+x9
*0.09+x10*0.07+x11*0.02+x12*0.1+x13*0.1)*(1+x14*0.2+x15*0.2+x16*0.11+
x17*0.15+x18*0.17+x19*0.21+x20*0.19)*(1+x26*0.2+x27*0.1+x28*0.15)*(1+
x29*0.2+x30*0.15)>=temp*3.43/4.12;

```

```

(1+x1*0.2+x2*0.2+x3*0.13+x4*0.05+x5*0.1)*
(1+x6*0.2+x7*0.13+x8*0.13+x9*
0.03+x10*0.05+x11*0.12+x12*0.05+x13*0.05)*
(1+x14*0.2+x15*0.2+x16*0.13+
x17*0.15+x18*0.17+x19*0.22+x20*0.21)*
(1+x21*0.15+x22*0.02+x23*0.01+x24*
0.01+x25*0.03)*(1+x26*0.2+x27*0.1+x28*0.15)*(1+x29*0.2+x30*0.15)
>=temp*
1/4.12;

```

```
x1+x2+x3+x4+x5<=1;  
x6+x7+x8+x9+x10+x11+x12+x13<=1;  
x14+x15+x16+x17+x18+x19+x20<=1;  
x21+x22+x23+x24+x25<=1;  
x26+x27+x28<=1;  
x29+x30<=1;  
x21=1;  
x26=1;
```